TÀI LIỆU ĐẶC TẢ API TÍCH HỢP
Hệ thống Mở tài khoản online có xác thực eKYC

Mã hợp đồng	N/A
Tên dự án	Mở tài khoản online có xác thực eKYC
Phân hệ	Đăng ký khách hàng / eKYC
Mã tài liệu	EKYC-API-SPEC-01
Phiên bản tài liệu	1.2

TRANG KÝ

I. SOẠN THẢO

TT	Họ tên	Chức vụ/Vai trò	Ngày ký	Chữ ký
1	Đào Đình Trung	BA	20/08/2026	Trung
2				
3				

II. KIỂM SOÁT

TT	Họ tên	Chức vụ/Vai trò	Ngày ký	Chữ ký
1				
2				
3				

III. PHÊ DUYỆT

TT	Họ tên	Chức vụ/Vai trò	Ngày ký	Chữ ký
1				
2				

BẢNG GHI NHẬN THAY ĐỔI PHIÊN BẢN

Ngày thay đổi	Phiên bản	Người thực hiện	Mô tả thay đổi
20/08/2026	0.1	Đào Đình Trung	Khởi tạo tài liệu, xác định phạm vi tích hợp và danh sách API.
28/08/2026	0.2	Đào Đình Trung	Bổ sung endpoint, phương thức và tham số đầu vào cho các API.
01/09/2026	1.0	Đào Đình Trung	Hoàn thiện response, ví dụ request/response và mã lỗi cơ bản.
05/09/2026	1.1	Đào Đình Trung	Bổ sung contract vendor giả lập và đối chiếu dữ liệu với SRS/CSDL.
11/09/2026	1.2	Đào Đình Trung	Đồng bộ quy tắc OTP/eKYC, xác nhận OCR, username và trạng thái hồ sơ.

MỤC LỤC

I. GIỚI THIỆU 6

1.1 Mục đích 6

1.2 Phạm vi 6

1.3 Tài liệu liên quan và giả định 6

II. KIẾN TRÚC TÍCH HỢP 7

2.1 Sơ đồ kiến trúc logic 7

2.2 Luồng xử lý tổng quan 8

III. CHI TIẾT TÍCH HỢP (INTEGRATION & ENDPOINT) 9

3.1 Quy ước chung 9

3.1.1 Base URL 9

3.1.2 Chuẩn dữ liệu và header 9

3.1.3 Response envelope 9

3.1.4 HTTP status sử dụng 9

3.2 Danh sách Service/API 10

3.3.1 API-01 - Gửi mã OTP 11

3.3.2 API-02 - Xác thực OTP 12

3.3.3 API-03 - Gửi ảnh CCCD để OCR 14

3.3.3 API-03 - Gửi ảnh CCCD để OCR (tiếp) 14

3.3.4 API-04 - Gửi dữ liệu khuôn mặt 16

3.3.4 API-04 - Gửi dữ liệu khuôn mặt (tiếp) 16

3.3.5 API-05 - Kiểm tra trạng thái hồ sơ 18

3.3.6 API-06 - Bổ sung thông tin đăng ký 20

3.3.7 API-07 - Xác nhận điều khoản và gửi hồ sơ 21

3.3.7 API-07 - Xác nhận điều khoản và gửi hồ sơ (tiếp) 22

3.3.8 API-08 - Thiết lập eBanking 23

3.3.9 EXT-01 - OCR trích xuất thông tin CCCD (Vendor) 25

3.3.9 EXT-01 - OCR trích xuất thông tin CCCD (Vendor) (tiếp) 25

3.3.10 EXT-02 - Face Matching và Liveness (Vendor) 27

IV. MÃ LỖI VÀ QUY TẮC NGHIỆP VỤ 28

4.1 Bảng mã lỗi chuẩn 28

4.2 Quy tắc nghiệp vụ chính 29

V. BẢO MẬT TÍCH HỢP 30

5.1 Xác thực và phân quyền 30

5.2 Bảo mật dữ liệu 31

5.3 Kiểm soát lỗi và dịch vụ phụ thuộc 31

VI. PHỤ LỤC 31

6.1 Trạng thái hồ sơ 31

6.2 Danh sách nội dung cần xác nhận trước UAT 31

CÁC TỪ VIẾT TẮT

STT	Từ viết tắt	Giải thích nghĩa
1	API	Application Programming Interface - Giao diện lập trình ứng dụng
2	CCCD	Căn cước công dân
3	CIF	Customer Information File - Mã khách hàng trên Core Banking
4	eKYC	Electronic Know Your Customer - Định danh khách hàng điện tử
5	JWT	JSON Web Token
6	OCR	Optical Character Recognition - Nhận dạng ký tự quang học
7	OTP	One-Time Password - Mật khẩu sử dụng một lần
8	M/O/C	Mandatory / Optional / Conditional - Bắt buộc / Không bắt buộc / Có điều kiện

I. Giới thiệu

1.1 Mục đích

Tài liệu mô tả hợp đồng giao tiếp giữa Mobile App, hệ thống Backend của ngân hàng và dịch vụ eKYC bên thứ ba trong quy trình mở tài khoản online. Nội dung được sử dụng làm đầu vào cho thiết kế kỹ thuật, phát triển tích hợp và xây dựng test case API.

1.2 Phạm vi

Phạm vi tài liệu gồm hai nhóm giao tiếp:

- API do Bank Backend cung cấp cho Mobile App: gửi/xác thực OTP, tiếp nhận dữ liệu eKYC, cập nhật và gửi hồ sơ, thiết lập eBanking.
- API do vendor eKYC cung cấp cho Bank Backend: OCR CCCD, Face Matching và Liveness Detection.

Ngoài phạm vi: khách hàng tổ chức/người nước ngoài; mở thêm tài khoản cho khách hàng hiện hữu; đọc NFC/VNeID; xét duyệt thủ công và tự động chuyển duyệt tay; chuyển khoản và sử dụng PIN khi giao dịch; chi trả hoa hồng; phát hành thẻ, ví điện tử; hạ tầng vận hành và phục hồi xuyên thiết bị. SRS, API, Database và prototype là tài liệu chi tiết của dự án, không nằm ngoài phạm vi tài liệu hóa.

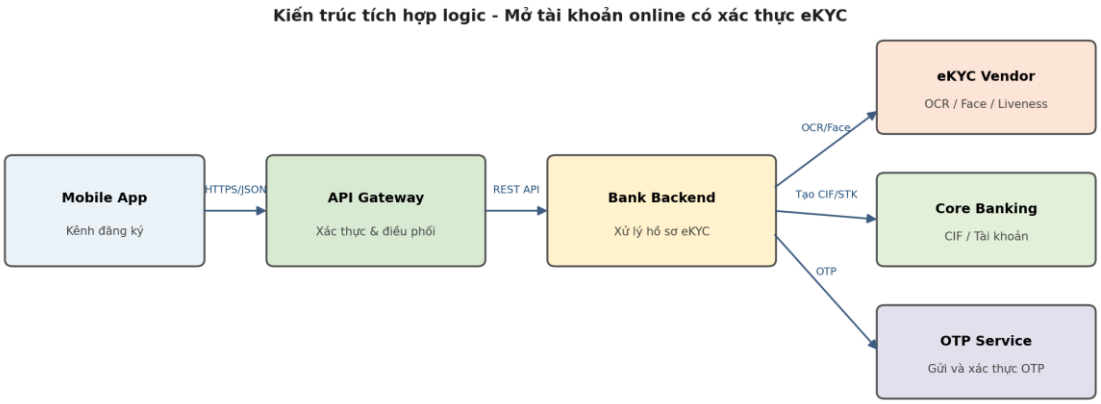
Đồ án cá nhân mô phỏng mở một tài khoản thanh toán cho khách hàng Việt Nam từ đủ 18 tuổi, có CCCD còn hiệu lực và chưa có CIF tại ngân hàng. Chụp hai mặt CCCD để OCR, không đọc chip/NFC; khách hàng xác nhận dữ liệu, thực hiện Face Matching và Liveness. Mã giới thiệu và chi nhánh hỗ trợ là tùy chọn. Chấp thuận điều khoản trước gửi hồ sơ; tạo MaKH nội bộ riêng với MaCIF trên Core; thông báo App và SMS; thiết lập tên đăng nhập, mật khẩu và PIN giao dịch. Chỉ hoàn tất khi Backend xác nhận đã lưu và kích hoạt eBanking. Quy trình OCR-only là giới hạn mô phỏng, chưa đại diện đầy đủ yêu cầu triển khai ngân hàng thực tế.

1.3 Tài liệu liên quan và giả định

Tài liệu/Đầu vào	Mục đích sử dụng
SRS - Mở tài khoản online có xác thực eKYC	Đối chiếu yêu cầu chức năng và phi chức năng.
Use Case / BPMN / Activity / Sequence Diagram	Đối chiếu luồng xử lý và các nhánh ngoại lệ.
Database Specification v1.2 — đặc tả 7 bảng và các quy tắc lưu của MVP	Đối chiếu trường dữ liệu, trạng thái hồ sơ và quan hệ dữ liệu.
Tài liệu API chính thức của vendor	TBD - cần bổ sung và xác nhận trước khi triển khai tích hợp.

II. Kiến trúc tích hợp

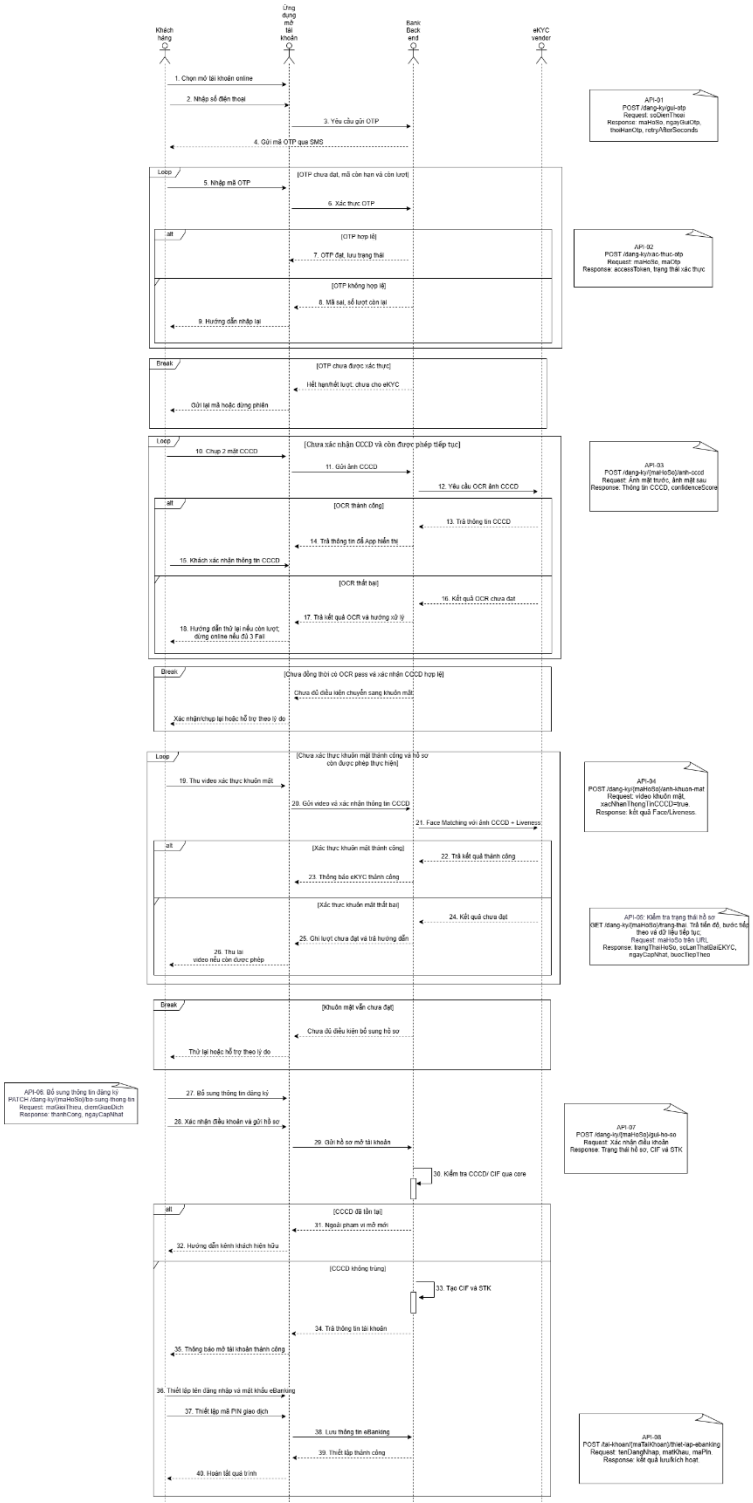
2.1 Sơ đồ kiến trúc logic



Hình 1. Kiến trúc tích hợp logic

Thành phần	Vai trò trong luồng
Mobile App	Thu thập dữ liệu đăng ký, ảnh CCCD, video khuôn mặt và hiển thị kết quả.
API Gateway	Kiểm soát truy cập, chuyển tiếp request và áp dụng chính sách bảo mật/rate limit.
Bank Backend	Quản lý hồ sơ, điều phối eKYC, kiểm tra quy tắc nghiệp vụ và chuẩn hóa response.
eKYC Vendor	Cung cấp OCR, Face Matching và Liveness Detection.
Core Banking	Kiểm tra/tạo CIF và tài khoản khi hồ sơ đủ điều kiện.
OTP Service	Gửi và xác thực mã OTP theo số điện thoại.

2.2 Luồng xử lý tổng quan



Hình 2. Sequence Diagram của quy trình mở tài khoản eKYC (Link)

Lưu ý: Sơ đồ thể hiện luồng chính và các nhánh ngoại lệ quan trọng: OTP, OCR, xác thực khuôn mặt và CCCD trùng. Quy tắc chi tiết, mã lỗi, giới hạn thử lại và tiếp tục sau gián đoạn được đặc tả tại từng API.

III. Chi tiết tích hợp (Integration & Endpoint)

3.1 Quy ước chung

3.1.1 Base URL

Nhóm API	Base URL	Ghi chú
Bank Backend	{{bank_api_base_url}}/v1	Cấu hình theo từng môi trường DEV/UAT/PROD.
eKYC Vendor	{{ekyc_vendor_base_url}}/v1	TBD - xác nhận theo tài liệu chính thức của vendor.

3.1.2 Chuẩn dữ liệu và header

- Encoding: UTF-8.
- Ngày giờ: Datetime trao đổi qua API dùng ISO 8601 kèm offset +07:00; Backend chuyển đổi sang UTC khi lưu DATETIME2 và đổi về +07:00 khi trả response. Các trường date như ngày sinh/ngày hết hạn dùng yyyy-MM-dd, không chuyển múi giờ.
- application/json cho API thông thường; multipart/form-data cho API upload ảnh/video.
- Mobile App gửi Authorization: Bearer <accessToken> sau khi xác thực OTP thành công.
- Bank Backend gọi vendor bằng X-API-Key hoặc cơ chế tương đương theo hợp đồng tích hợp.

3.1.3 Response envelope

Các API do Bank Backend cung cấp sử dụng cấu trúc response thống nhất:

```
{
  "success": true,
  "data": {},
  "error": null
}
```

Trường error chỉ có giá trị khi success = false; data trả về null trong trường hợp lỗi.

error gồm code (string), message (string) và details (object, có điều kiện). Lỗi eKYC có details.soLanThatBaiEKYC (integer 0–3), coTheThuLai (boolean), trangThaiHoSo (string). App xác định quay lại CCCD hay khuôn mặt từ API đang lỗi và UC tương ứng. Lỗi giới hạn OTP có details.retryAfterSeconds (integer, số giây còn chờ). Response Pass dùng data; response lỗi không đặt dữ liệu nghiệp vụ vào data.

3.1.4 HTTP status sử dụng

HTTP status	Ý nghĩa
200 OK	Xử lý thành công.
201 Created	Tạo mới tài nguyên thành công.
400 Bad Request	Request không hợp lệ hoặc vi phạm điều kiện đầu vào.
401 Unauthorized	Thiếu hoặc sai thông tin xác thực.
404 Not Found	Không tìm thấy tài nguyên.

HTTP status	Ý nghĩa
409 Conflict	Xung đột trạng thái hoặc dữ liệu.
422 Unprocessable Entity	Dữ liệu đúng định dạng nhưng không đạt điều kiện nghiệp vụ.
429 Too Many Requests	Vượt tần suất gọi API.
500 Internal Server Error	Lỗi xử lý nội bộ.
503 Service Unavailable	Dịch vụ phụ thuộc tạm thời gián đoạn.
202 Accepted	Đã tiếp nhận; đang chờ kết quả tạo tài khoản.

3.2 Danh sách Service/API

No.	Nhóm	ID	Method	Endpoint	Tên API
1	Mobile - Bank	API-01	POST	/dang-ky/gui-otp	Gửi mã OTP
2	Mobile - Bank	API-02	POST	/dang-ky/xac-thuc-otp	Xác thực OTP
3	Mobile - Bank	API-03	POST	/dang-ky/{maHoSo}/anh-cccd	Gửi ảnh CCCD để OCR
4	Mobile - Bank	API-04	POST	/dang-ky/{maHoSo}/anh-khuon-mat	Gửi dữ liệu khuôn mặt
5	Mobile - Bank	API-05	GET	/dang-ky/{maHoSo}/trang-thai	Kiểm tra trạng thái hồ sơ
6	Mobile - Bank	API-06	PATCH	/dang-ky/{maHoSo}/bo-sung-thong-tin	Bổ sung thông tin đăng ký
7	Mobile - Bank	API-07	POST	/dang-ky/{maHoSo}/gui-ho-so	Xác nhận điều khoản và gửi hồ sơ
8	Mobile - Bank	API-08	POST	/tai-khoan/{maTaiKhoan}/thiet-lap-ebanking	Thiết lập eBanking
9	Bank - Vendor	EXT-01	POST	/ocr	OCR trích xuất thông tin CCCD (Vendor)
10	Bank - Vendor	EXT-02	POST	/face-match	Face Matching và Liveness (Vendor)

Phạm vi: API-01 đến API-08 là contract do Bank Backend cung cấp. EXT-01 và EXT-02 là contract dự kiến với vendor, cần xác nhận trước khi phát triển.

3.3.1 API-01 - Gửi mã OTP

Mô tả: Tạo hồ sơ đăng ký ở trạng thái xử lý ban đầu và gửi mã OTP tới số điện thoại khách hàng. Tạo hồ sơ mới hoặc gửi/xác thực lại OTP trên hồ sơ có sẵn; không tạo maHoSo mới khi maHoSo đã được truyền.

URL (Endpoint): /dang-ky/gui-otp

Phương thức (Method): POST

Xác thực: Không yêu cầu access token

Content-Type: application/json

Use Case liên quan: UC01 - Xác thực số điện thoại

Request parameters

Field Name	Type	In	Mandatory	Description
soDienThoai	string	body	M	Số điện thoại Việt Nam, định dạng 0xxxxxxxxx.
maHoSo	integer	body	O	Có khi gửi lại/tiếp tục; SĐT phải khớp hồ sơ đã lưu; chưa cấp quyền đọc trước OTP.

Request example

```
{
  "soDienThoai": "0901234567"
}
```

Response data

Field Name	Type	Mandatory	Description
maHoSo	integer	M	Mã hồ sơ mới hoặc hồ sơ được tiếp tục.
ngayGuiOtp	datetime	M	Thời điểm gửi OTP theo ISO 8601.
thoiHanOtp	integer	M	300 giây theo cấu hình đồ án BR-OTP.
retryAfterSeconds	integer	M	Số giây chờ trước lần gửi tiếp theo (thường 60, có thể dài hơn do cửa sổ giới hạn).

Response example

```
{
"success": true,
"data": {
"maHoSo": 1025,
"ngayGuiOtp": "2026-08-04T09:15:00+07:00",
"thoiHanOtp": 300,
```

```
"retryAfterSeconds": 60
},
"error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
400	SDT_KHONG_HOP_LE	Số điện thoại không đúng định dạng.
429	QUA_NHIEU_YEU_CAU	Yêu cầu gửi OTP vượt tần suất cho phép.

Quy tắc/Ghi chú nghiệp vụ

- BR-OTP: OTP gồm 6 số, hiệu lực 300 giây; chỉ mã mới nhất được dùng và chỉ dùng một lần. Tối đa 5 lần nhập sai trong một chu kỳ xác thực của hồ sơ; gửi lại không đặt lại số lần sai. Đạt giới hạn: tạm khóa xác thực 15 phút rồi cho bắt đầu chu kỳ mới. Chờ 60 giây giữa hai lần gửi; tối đa 3 lần gửi thành công trong 5 phút theo SĐT, tính cả lần đầu.
- Gửi lại không đặt lại bộ đếm nhập sai. API-01 nhận maHoSo khi tiếp tục; SĐT phải khớp hồ sơ. OTP thành công không được hạ trạng thái DaMoTaiKhoan/HoanTat về trạng thái ban đầu.

3.3.2 API-02 - Xác thực OTP

Mô tả: Xác thực mã OTP khách hàng nhập. Nếu hợp lệ, hệ thống cấp access token cho các bước tiếp theo.

URL (Endpoint): /dang-ky/xac-thuc-otp

Phương thức (Method): POST

Xác thực: Không yêu cầu access token

Content-Type: application/json

Use Case liên quan: UC01 - Xác thực số điện thoại

Request parameters

Field Name	Type	In	Mandatory	Description
maHoSo	integer	body	M	Mã hồ sơ nhận từ API-01.
maOtp	string	body	M	Mã OTP khách hàng nhập.

Request example

```
{
  "maHoSo": 1025,
  "maOtp": "438219"
}
```

Response data

Field Name	Type	Mandatory	Description
hopLe	boolean	M	Kết quả xác thực OTP.
accessToken	string	M	JWT dùng cho các API tiếp theo.
trangThaiHoSo	string	M	Trạng thái hồ sơ sau xác thực.

Response example

```
{
  "success": true,
  "data": {
    "hopLe": true,
    "accessToken": "<onboarding-token>",
    "trangThaiHoSo": "DangThucHien"
  },
  "error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
400	ERR_OTP_001	OTP không hợp lệ; hiển thị P-OTP-001 và cho nhập lại khi mã còn hiệu lực, chưa đủ 5 lần nhập sai theo BR-OTP. Đủ 5 lần trả OTP_QUA_SO_LAN_THU và thời gian khóa còn lại.
400	OTP_HET_HAN	Mã OTP đã hết hiệu lực.
404	HOSO_KHONG_TON_TAI	Không tìm thấy hồ sơ theo maHoSo.
429	OTP_QUA_SO_LAN_THU	Đủ 5 lần sai; retryAfterSeconds thể hiện thời gian khóa còn lại.

Quy tắc/Ghi chú nghiệp vụ

- API-RULE-TOKEN: token onboarding 30 phút (giả định), gắn đúng hồ sơ. Hết hạn xác thực lại bằng API-01/02 cùng maHoSo.

3.3.3 API-03 - Gửi ảnh CCCD để OCR

Mô tả: Tiếp nhận ảnh mặt trước và mặt sau CCCD, gọi dịch vụ OCR của vendor và trả về thông tin trích xuất.

URL (Endpoint): /dang-ky/{maHoSo}/anh-cccd

Phương thức (Method): POST

Xác thực: Bearer access token

Content-Type: multipart/form-data

Use Case liên quan: UC03 - Chụp ảnh CCCD

Request parameters

Field Name	Type	In	Mandatory	Description
maHoSo	integer	path	M	Mã hồ sơ đăng ký.
anhMatTruoc	file	form-data	M	Ảnh mặt trước CCCD.
anhMatSau	file	form-data	M	Ảnh mặt sau CCCD.

Request example

```
POST /dang-ky/1025/anh-cccd
Content-Type: multipart/form-data

anhMatTruoc: (file) front.jpg
anhMatSau: (file) back.jpg
```

3.3.3 API-03 - Gửi ảnh CCCD để OCR (tiếp)

Response data

Field Name	Type	Mandatory	Description
ketQua	string	M	Pass trong response success=true. Fail nghiệp vụ trả success=false, data=null và chi tiết tại error.details theo mục 3.1.3.
confidenceScore	decimal	M	Điểm tin cậy OCR từ 0 đến 100.
hoTen	string	C	Họ tên; trả về khi ketQua = Pass.
soCCCD	string	C	Số CCCD; trả về khi ketQua = Pass.
ngaySinh	date	C	Ngày sinh; trả về khi ketQua = Pass.
diaChi	string	C	Địa chỉ; trả về khi ketQua = Pass.
soLanThatBaiEKYC	integer	M	Tổng Fail nghiệp vụ OCR và Face/Liveness của hồ sơ, từ 0 đến

Field Name	Type	Mandatory	Description
			3. Pass không tăng hoặc reset. Khác LanThu là số thứ tự yêu cầu trong lịch sử CSDL.
coTheThuLai	boolean	M	Cho biết hồ sơ còn được phép thực hiện lại eKYC trước khi gửi theo trạng thái và giới hạn; không yêu cầu thử lại khi kết quả đã Pass
gioiTinh	string	C	Nam/Nu/Khac, bắt buộc khi Pass theo mock.
ngayHetHan	date	C	yyyy-MM-dd, bắt buộc khi Pass; hết hạn dừng luồng.

Response example


```
{
  "success": true,
  "data": {
    "ketQua": "Pass",
    "confidenceScore": 96.8,
    "hoTen": "NGUYEN VAN AN",
    "soCCCD": "001090001001",
    "ngaySinh": "1990-01-15",
    "gioiTinh": "Nam",
    "ngayHetHan": "2030-01-15",
    "diaChi": "Ba Dinh, Ha Noi",
    "soLanThatBaiEKYC": 0,
    "coTheThuLai": true
  },
  "error": null
}
```


Mã lỗi

HTTP	Error code	Tình huống
401	TOKEN_KHONG_HOP_LE	Access token thiếu, sai hoặc hết hạn.
422	KHONG_DU_DIEU_KIEN	Khách hàng dưới 18 tuổi hoặc CCCD hết hiệu lực; dừng online, không tăng Fail vendor.
409	ERR_EKYC_003	Tổng thất bại eKYC đã đạt 3; hiển thị P-EKYC-002 và dừng online, hướng dẫn hỗ trợ/quầy.

Quy tắc/Ghi chú nghiệp vụ

- BR-MOCK: Khi OCR trả dữ liệu đủ tin cậy, Backend kiểm tra dữ liệu bắt buộc, tuổi từ đủ 18 và hiệu lực CCCD trước khi trả success=true. Nếu xác định dưới 18 tuổi hoặc giấy tờ hết hiệu lực,

trả 422 KHONG_DU_DIEU_KIEN, cập nhật KhongHoanTatOnline và không tăng bộ đếm Fail của vendor.

- BR-EKYC: OCR và Face/Liveness dùng chung soLanThatBaiEKYC theo maHoSo, bắt đầu bằng 0. Mỗi yêu cầu được vendor xử lý và trả Fail tính 1 lần; Pass không tăng hoặc đặt lại bộ đếm. Cả Face và Liveness cùng Fail chỉ tính 1 lần. Lỗi mạng, timeout, file sai MIME/dung lượng và thao tác tự chụp lại chưa gửi không tăng bộ đếm. Đủ 3 lần: KhongHoanTatOnline, dừng online và hướng dẫn hỗ trợ/quầy; không tạo hàng đợi duyệt thủ công.
- Ảnh CCCD mới làm mất hiệu lực xác nhận OCR và kết quả Face cũ. Lưu kết quả OCR hiện hành; API-04 nhận xác nhận khách hàng trước khi xử lý Face.

3.3.4 API-04 - Gửi dữ liệu khuôn mặt

Mô tả: Tiếp nhận video MP4 khuôn mặt thu trực tiếp, thực hiện Face Matching và Liveness qua vendor giả lập.

URL (Endpoint): /dang-ky/{maHoSo}/anh-khuon-mat

Phương thức (Method): POST

Xác thực: Bearer access token

Content-Type: multipart/form-data

Use Case liên quan: UC04 – Xác thực khuôn mặt

Request parameters

Field Name	Type	In	Mandatory	Description
maHoSo	integer	path	M	Mã hồ sơ đăng ký.
anhKhuonMat	file	form-data	M	Video MP4 thu trực tiếp trong bước xác thực, tối đa 10 MiB và 10 giây theo mock contract tại mục 5.3.
xacNhanThongTinCCCD	boolean	form-data	M	Phải true và OCR hiện hành Pass; trên multipart là chuỗi true/false được Backend chuyển kiểu.

Request example

```
POST /dang-ky/1025/anh-khuon-mat
Content-Type: multipart/form-data
anhKhuonMat: (file) selfie.mp4
xacNhanThongTinCCCD: true
```

3.3.4 API-04 - Gửi dữ liệu khuôn mặt (tiếp)

Response data

Field Name	Type	Mandatory	Description
ketQua	string	M	Pass trong response success=true. Fail nghiệp vụ trả success=false,

Field Name	Type	Mandatory	Description
			data=null và chi tiết tại error.details theo mục 3.1.3.
confidenceScore	decimal	M	Điểm tin cậy so khớp khuôn mặt.
livenessPass	boolean	M	Kết quả kiểm tra liveness.
soLanThatBaiEKYC	integer	M	Tổng Fail nghiệp vụ OCR và Face/Liveness của hồ sơ, từ 0 đến 3
coTheThuLai	boolean	M	Hồ sơ còn được phép thực hiện lại eKYC trước khi gửi theo trạng thái và giới hạn; true không yêu cầu thử lại khi kết quả đã Pass

Response example

```
{
  "success": true,
  "data": {
    "ketQua": "Pass",
    "confidenceScore": 94.6,
    "livenessPass": true,
    "soLanThatBaiEKYC": 1,
    "coTheThuLai": true
  },
  "error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
401	TOKEN_KHONG_HOP_LE	Access token thiếu, sai hoặc hết hạn.
422	ERR_EKYC_002	Face Matching dưới 85 trên thang 0–100 hoặc Liveness không đạt; tổng Fail nghiệp vụ sau cập nhật <3
409	ERR_EKYC_003	Tổng Fail nghiệp vụ eKYC đã đạt 3; đặt KhongHoanTatOnline, hiển thị P-EKYC-002, dừng online và hướng dẫn hỗ trợ/đến quầy. Không chuyển xét duyệt thủ công.

Quy tắc/Ghi chú nghiệp vụ

- BR-MOCK: Face chỉ Pass khi confidenceScore ≥85 và livenessPass=true; thang 0–100 giả lập.
- BR-EKYC: OCR và Face/Liveness dùng chung soLanThatBaiEKYC theo maHoSo, bắt đầu bằng 0. Mỗi yêu cầu được vendor xử lý và trả Fail tính 1 lần; Pass không tăng hoặc đặt lại bộ đếm. Cả Face và Liveness cùng Fail chỉ tính 1 lần. Lỗi mạng, timeout, file sai MIME/dung lượng và

thao tác tự chụp lại chưa gửi không tăng bộ đếm. Đủ 3 lần: KhongHoanTatOnline, dừng online và hướng dẫn hỗ trợ/quầy; không tạo hàng đợi duyệt thủ công.

3.3.5 API-05 - Kiểm tra trạng thái hồ sơ

Mô tả: Truy vấn trạng thái xử lý mới nhất của hồ sơ đăng ký.

URL (Endpoint): /dang-ky/{maHoSo}/trang-thai

Phương thức (Method): GET

Xác thực: Bearer access token

Content-Type: application/json

Use Case liên quan: hỗ trợ tra cứu và tiếp tục các UC01–UC09 theo BR-RESUME/BR-RETRY; liên kết US18 trong User Story Map.

Request parameters

Field Name	Type	In	Mandatory	Description
maHoSo	integer	path	M	Mã hồ sơ đăng ký.

Request example

```
GET /dang-ky/1025/trang-thai
Authorization: Bearer <onboarding-token>

Không có request body.
```

Response data

Field Name	Type	Mandatory	Description
trangThaiHoSo	string	M	DangThucHien, DangXuLy, DaMoTaiKhoan, HoanTat, KhongHoanTatOnline, TuChoiMoMoi hoặc HetHanNhap; theo phụ lục 6.1.
soLanThatBaiEKYC	integer	M	Tổng Fail nghiệp vụ của hồ sơ, 0–3.
ngayCapNhat	datetime	M	Thời điểm cập nhật hồ sơ gần nhất, ISO 8601.
buocTiepTheo	string	M	ChupCCCD, XacNhanCCCD, XacThucKhuonMat, HoanThienHoSo, ChoKetQua, ThietLapEBanking hoặc KetThuc.
thongTinCCCD	object	C	Trả khi cần hiển thị lại dữ liệu OCR hiện hành; cùng 6 trường dữ liệu cá nhân của API-03.
maTaiKhoan	integer	C	Bắt buộc khi DaMoTaiKhoan hoặc HoanTat. Dùng để gọi API-08 khi còn cần thiết lập.

Field Name	Type	Mandatory	Description
soTaiKhoan	string	C	Bắt buộc khi DaMoTaiKhoan hoặc HoanTat; dùng hiển thị kết quả.
thongTinBoSung	object	C	Trả khi buocTiepTheo = HoanThienHoSo; gồm maGioiThieu và diemGiaoDich đã lưu, mỗi trường là string hoặc null.

thongTinCCCD gồm hoTen, soCCCD, ngaySinh, gioiTinh, diaChi, ngayHetHan. Chỉ trả dữ liệu của hồ sơ được token cho phép. buocTiepTheo do Backend suy ra từ trạng thái và cờ hiện hành trong CSDL, không cần thêm cột cùng tên. Khi không đáp ứng điều kiện trả một trường C, bỏ trường đó khỏi response.

Bảng quy tắc buocTiepTheo:

Điều kiện	buocTiepTheo
DangThucHien, OCR hiện hành chưa Pass	ChupCCCD
DangThucHien, OCR Pass, Backend chưa ghi nhận xác nhận	XacNhanCCCD
DangThucHien, đã xác nhận nhưng Face hoặc Liveness chưa đạt	XacThucKhuonMat
DangThucHien, OCR/xác nhận/Face/Liveness đều đạt	HoanThienHoSo
DangXuLy	ChoKetQua
DaMoTaiKhoan	ThietLapEBanking
HoanTat hoặc trạng thái dừng	KetThuc

Response example


```
{
"success": true,
"data": {
"trangThaiHoSo": "DaMoTaiKhoan",
"soLanThatBaiEKYC": 0,
"ngayCapNhat": "2026-08-04T09:30:00+07:00",
"buocTiepTheo": "ThietLapEBanking",
"maTaiKhoan": 8801,
"soTaiKhoan": "100000000001"
},
"error": null
}
```


Mã lỗi

HTTP	Error code	Tình huống
401	TOKEN_KHONG_HOP_LE	Access token thiếu, sai hoặc hết hạn.
404	HOSO_KHONG_TON_TAI	Không tìm thấy hồ sơ theo maHoSo.

3.3.6 API-06 - Bổ sung thông tin đăng ký

Mô tả: Cập nhật mã giới thiệu và/hoặc điểm giao dịch liên kết cho hồ sơ.
URL (Endpoint): /dang-ky/{maHoSo}/bo-sung-thong-tin
Phương thức (Method): PATCH
Xác thực: Bearer access token
Content-Type: application/json
Use Case liên quan: UC05 - Nhập thông tin bổ sung

Request parameters

Field Name	Type	In	Mandatory	Description
maHoSo	integer	path	M	Mã hồ sơ đăng ký.
maGioiThieu	string hoặc null	body	O	Tùy chọn, tối đa 20 ký tự; giá trị khác null phải tồn tại/còn hiệu lực trong danh mục giả lập. Không truyền: giữ nguyên. null: xóa.
diemGiaoDich	string hoặc null	body	O	Mã chi nhánh hỗ trợ tùy chọn, tối đa 100 ký tự; phải thuộc danh mục giả lập khi có giá trị. UI hiển thị tên. Không truyền: giữ nguyên. null: xóa.

Request example

```
{
  "maGioiThieu": "GT001",
  "diemGiaoDich": "CN001"
}
```

Response data

Field Name	Type	Mandatory	Description
thanhCong	boolean	M	Kết quả cập nhật.
ngayCapNhat	datetime	M	Thời điểm cập nhật gần nhất.

Response example

```
{
  "success": true,
  "data": {
    "thanhCong": true,
    "ngayCapNhat": "2026-08-04T09:25:00+07:00"
  },
  "error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
400	DU_LIEU_KHONG_HOP_LE	Thông tin bổ sung không đúng định dạng.
401	TOKEN_KHONG_HOP_LE	Access token thiếu, sai hoặc hết hạn.
404	HOSO_KHONG_TON_TAI	Không tìm thấy hồ sơ theo maHoSo.

Quy tắc/Ghi chú nghiệp vụ

- maGioiThieu, diemGiaoDich tùy chọn; không truyền thì giữ nguyên; truyền null thì xóa giá trị đã lưu. maGioiThieu tối đa 20 ký tự, phải tồn tại/còn hiệu lực trong danh mục giả lập. diemGiaoDich là mã chi nhánh hỗ trợ, không tự nâng gói tài khoản. Chỉ cập nhật sau eKYC đạt và trước gửi.

3.3.7 API-07 - Xác nhận điều khoản và gửi hồ sơ

Mô tả: Xác nhận điều khoản, kiểm tra CCCD trùng lặp và tạo khách hàng/CIF/tài khoản khi hồ sơ hợp lệ.

URL (Endpoint): /dang-ky/{maHoSo}/gui-ho-so

Phương thức (Method): POST

Xác thực: Bearer access token

Content-Type: application/json

Use Case liên quan: UC06 - Gửi hồ sơ đăng ký

Request parameters

Field Name	Type	In	Mandatory	Description
maHoSo	integer	path	M	Mã hồ sơ đăng ký.
xacNhanDieuKhoan	boolean	body	M	Phải bằng true để tiếp tục xử lý.
phienBanDieuKhoan	string	body	M	Phiên bản nội dung đã hiển thị; demo DK-1.0. Backend kiểm tra phiên bản được hỗ trợ.

Request example

```
{
  "xacNhanDieuKhoan": true,
  "phienBanDieuKhoan": "DK-1.0"
}
```

3.3.7 API-07 - Xác nhận điều khoản và gửi hồ sơ (tiếp)

Response data

Field Name	Type	Mandatory	Description
trangThaiHoSo	string	M	DaMoTaiKhoan sau tạo; HoanTat nếu trả lại hồ sơ đã thiết lập. Với 202 là DangXuLy.
maTaiKhoan	integer	C	Khóa định danh tài khoản trong hệ thống. Có khi tạo thành công, không trả khi 202.
soTaiKhoan	string	C	Số tài khoản thanh toán được cấp. Có khi tạo thành công, không trả khi 202.
maCIF	string	C	Mã khách hàng trên Core Banking. Có khi tạo thành công, không trả khi 202.
maKH	integer	C	Mã khách hàng nội bộ, khác maCIF; có sau tạo khách hàng.
maHoSo	integer	M	Mã hồ sơ xử lý.
buocTiepTheo	string	M	ChoKetQua, ThietLapEBanking hoặc KetThuc.

Response example

```
{
  "success": true,
  "data": {
    "maHoSo": 1025,
    "trangThaiHoSo": "DaMoTaiKhoan",
    "maKH": 501,
    "maTaiKhoan": 8801,
    "soTaiKhoan": "100000000001",
    "maCIF": "CIF000001",
    "buocTiepTheo": "ThietLapEBanking"
  },
  "error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
400	CHUA_XAC_NHAN_DIEU_KHOAN	Khách hàng chưa xác nhận điều khoản.

HTTP	Error code	Tình huống
409	ERR_CCCD_001	CCCD đã tồn tại trong dữ liệu khách hàng chính thức; hiển thị P-DUP-001 và từ chối hồ sơ.
422	HOSO_CHUA_DU_DIEU_KIEN	Hồ sơ chưa hoàn tất các bước eKYC bắt buộc.
422	KHONG_DU_DIEU_KIEN	Không đáp ứng tuổi/hiệu lực giấy tờ tại thời điểm gửi mới; không tạo CIF/tài khoản.

Quy tắc/Ghi chú nghiệp vụ

- BR-RETRY: Gửi lại cùng maHoSo không tạo thêm MaKH, CIF hoặc tài khoản. Nếu đã tạo tài khoản, trả kết quả hiện có. Nếu Core đã tạo CIF nhưng tài khoản chưa xong, tiếp tục đúng CIF của hồ sơ này. Khi chưa biết kết quả Core, giữ DangXuLy và tra cứu trước khi thử lại; không báo thành công hoặc tạo mới một cách mù quáng.
- Chỉ gửi khi xacNhanDieuKhoan=true, SĐT đã xác thực và token onboarding còn hiệu lực, OCR hiện hành và xác nhận khách hàng đã có, Face/Liveness đạt; còn trong phạm vi khách hàng mới. Backend lưu thời điểm đồng ý và phiên bản điều khoản.

API-07 trả 200 khi đã xác định mở tài khoản thành công. Nếu đang chờ/chưa rõ kết quả Core trả 202, data gồm trangThaiHoSo=DangXuLy, maHoSo và buocTiepTheo=ChoKetQua; App dùng API-05 tra cứu. SMS thông báo được xử lý riêng và không quyết định kết quả API-07.

3.3.8 API-08 - Thiết lập eBanking

Mô tả: Tiếp nhận tên đăng nhập, mật khẩu và PIN để thiết lập eBanking cho tài khoản đã mở. Backend kiểm tra, tạo hash, lưu và kích hoạt thành công mới trả HoanTat.

URL (Endpoint): /tai-khoan/{maTaiKhoan}/thiet-lap-ebanking

Phương thức (Method): POST

Xác thực: Bearer access token

Content-Type: application/json

Use Case liên quan: UC09 - Thiết lập eBanking

Request parameters

Field Name	Type	In	Mandatory	Description
maTaiKhoan	integer	path	M	Mã tài khoản nhận từ API-07 hoặc API-05; phải thuộc hồ sơ/khách hàng mà token cho phép.
matKhau	string	body	M	8–20 ký tự, có chữ hoa, chữ thường, số và ký tự đặc biệt; không khoảng trắng, không trùng tên đăng nhập, theo BR-CREDENTIAL.
maPin	string	body	M	Mã PIN gồm 6 chữ số.

Field Name	Type	In	Mandatory	Description
tenDangNhap	string	body	M	Theo BR-CREDENTIAL; duy nhất không phân biệt hoa/thường.

Request example

```
{
  "tenDangNhap": "trung.demo",
  "matKhau": "Demo@2026",
  "maPin": "836214"
}
```

Response data

Field Name	Type	Mandatory	Description
thanhCong	boolean	M	Kết quả thiết lập eBanking.
ngayThietLap	datetime	M	Thời điểm thiết lập thành công.
trangThaiHoSo	string	M	HoanTat sau lưu và kích hoạt thành công.

Response example

```
{
  "success": true,
  "data": {
    "thanhCong": true,
    "ngayThietLap": "2026-10-11T09:31:00+07:00",
    "trangThaiHoSo": "HoanTat"
  },
  "error": null
}
```

Mã lỗi

HTTP	Error code	Tình huống
400	MAT_KHAU_KHONG_DU_MANH	Mật khẩu không đạt yêu cầu độ mạnh.
400	MA_PIN_KHONG_HOP_LE	Mã PIN không đúng định dạng.
409	TEN_DANG_NHAP_DA_TON_TAI	Tên đăng nhập đã thuộc khách hàng khác.
400	TEN_DANG_NHAP_KHONG_HOP_LE	Không đạt định dạng BR-CREDENTIAL.

Quy tắc/Ghi chú nghiệp vụ

- BR-CREDENTIAL: Tên đăng nhập 6–50 ký tự gồm chữ Latin không dấu, số, dấu chấm hoặc gạch dưới; duy nhất không phân biệt hoa/thường, không có khoảng trắng. Mật khẩu 8–20 ký tự, có chữ hoa, chữ thường, số và ký tự đặc biệt; không khoảng trắng, không trùng tên đăng nhập. PIN là chuỗi đúng 6 chữ số; chặn 111111 và 123456; nhập lại phải khớp. Đăng nhập bằng tên đã thiết lập; đăng nhập bằng SĐT ngoài phạm vi.
- Mật khẩu và PIN chỉ được lưu dưới dạng hash; không ghi plaintext vào database hoặc log.

API-08 kiểm tra toàn bộ đầu vào trước lưu. Chưa lưu thành công: hồ sơ giữ DaMoTaiKhoan. Đã HoanTat mà gọi lại: trả kết quả thiết lập hiện có, không thay username/mật khẩu/PIN; thay đổi thông tin là luồng ngoài MVP. Kết quả trả về không chứa bí mật.

3.3.9 EXT-01 - OCR trích xuất thông tin CCCD (Vendor)

Mô tả: API dự kiến do vendor eKYC cung cấp để trích xuất thông tin từ ảnh CCCD gắn chip.

URL (Endpoint): /ocr

Phương thức (Method): POST

Xác thực: X-API-Key

Content-Type: application/json

Use Case liên quan: Tích hợp nội bộ của API-03

Request parameters

Field Name	Type	In	Mandatory	Description
anhMatTruoc	base64 string	body	M	Ảnh mặt trước CCCD đã mã hóa base64.
anhMatSau	base64 string	body	M	Ảnh mặt sau CCCD đã mã hóa base64.

Request example

```
{
  "anhMatTruoc": "<base64_front>",
  "anhMatSau": "<base64_back>"
}
```

3.3.9 EXT-01 - OCR trích xuất thông tin CCCD (Vendor) (tiếp)

Response data

Field Name	Type	Mandatory	Description
ketQua	string	M	Pass hoặc Fail.
confidenceScore	decimal	M	Điểm tin cậy OCR từ 0 đến 100.

Field Name	Type	Mandatory	Description
hoTen	string	C	Họ tên trích xuất.
soCCCD	string	C	Số CCCD trích xuất.
ngaySinh	date	C	Ngày sinh trích xuất.
diaChi	string	C	Địa chỉ trích xuất.
gioiTinh	string	C	Nam/Nu/Khac, bắt buộc khi Pass theo mock.
ngayHetHan	date	C	yyyy-MM-dd, bắt buộc khi Pass; hết hạn dừng luồng.

Response example

```
{
  "ketQua": "Pass",
  "confidenceScore": 96.8,
  "hoTen": "NGUYEN VAN AN",
  "soCCCD": "001090001001",
  "ngaySinh": "1990-01-15",
  "gioiTinh": "Nam",
  "ngayHetHan": "2030-01-15",
  "diaChi": "Ba Dinh, Ha Noi"
}
```

Mã lỗi

HTTP	Error code	Tình huống
422	IMAGE_UNREADABLE	Ảnh không đọc được.
503	SERVICE_UNAVAILABLE	Dịch vụ eKYC tạm thời gián đoạn.

Quy tắc/Ghi chú nghiệp vụ

- Contract này là đề xuất tích hợp. Tên trường, cơ chế ký request và mã lỗi phải đối chiếu tài liệu chính thức của vendor trước khi phát triển.

3.3.10 EXT-02 - Face Matching và Liveness (Vendor)

Mô tả: API dự kiến do vendor eKYC cung cấp để so khớp khuôn mặt và kiểm tra liveness.
URL (Endpoint): /face-match
Phương thức (Method): POST
Xác thực: X-API-Key
Content-Type: application/json
Use Case liên quan: Tích hợp nội bộ của API-04

Request parameters

Field Name	Type	In	Mandatory	Description
anhCCCD	base64 string	body	M	Ảnh mặt trước CCCD hiện hành đã lưu; mock vendor dùng ảnh này để đối chiếu khuôn mặt.
anhKhuonMat	base64 string	body	M	Video MP4 xác thực khuôn mặt theo giới hạn mục 5.3, mã hóa base64 khi gọi mock vendor.

Request example

```
{
"anhCCCD": "<base64_front_cccd>",
"anhKhuonMat": "<base64_selfie_mp4>"
}
```

Response data

Field Name	Type	Mandatory	Description
ketQua	string	M	Pass hoặc Fail.
confidenceScore	decimal	M	Điểm tin cậy so khớp từ 0 đến 100.
livenessPass	boolean	M	Kết quả kiểm tra liveness.

Response example

```
{
  "ketQua": "Pass",
  "confidenceScore": 94.6,
  "livenessPass": true
}
```

Mã lỗi

HTTP	Error code	Tình huống
422	LIVENESS_FAILED	Phát hiện nguy cơ giả mạo hoặc liveness không đạt.
503	SERVICE_UNAVAILABLE	Dịch vụ eKYC tạm thời gián đoạn.

Quy tắc/Ghi chú nghiệp vụ

- Contract này là đề xuất tích hợp và cần được vendor xác nhận trước khi phát triển.

IV. Mã lỗi và quy tắc nghiệp vụ

4.1 Bảng mã lỗi chuẩn

Error code	HTTP	Mô tả
SDT_KHONG_HOP_LE	400	Số điện thoại không đúng định dạng.
ERR_OTP_001	400	OTP không hợp lệ; hiển thị P-OTP-001 và cho nhập lại khi còn hạn/còn lượt theo BR-OTP.
OTP_HET_HAN	400	Mã OTP hết hiệu lực.
DU_LIEU_KHONG_HOP_LE	400	Dữ liệu đầu vào không hợp lệ.
CHUA_XAC_NHAN_DIEU_KHOAN	400	Chưa xác nhận điều khoản sử dụng.
MAT_KHAU_KHONG_DU_MANH	400	Mật khẩu không đạt yêu cầu.
MA_PIN_KHONG_HOP_LE	400	Mã PIN không đúng định dạng.
TOKEN_KHONG_HOP_LE	401	Access token thiếu, sai hoặc hết hạn.
HOSO_KHONG_TON_TAI	404	Không tìm thấy hồ sơ.
ERR_CCCD_001	409	CCCD đã tồn tại trong dữ liệu khách hàng chính thức; hiển thị P-DUP-001 và từ chối hồ sơ.
ERR_EKYC_003	409	Tổng thất bại eKYC đã đạt 3; hiển thị P-EKYC-002 và dừng online, hướng dẫn hỗ trợ/quầy.
ERR_EKYC_001	422	OCR không trích xuất được thông tin CCCD; khi tổng thất bại eKYC < 3, hiển thị P-EKYC-001.
ERR_EKYC_002	422	Face Matching dưới 85 trên thang 0–100 hoặc Liveness Detection không đạt; khi tổng thất bại eKYC < 3, hiển thị P-EKYC-001.

Error code	HTTP	Mô tả
HOSO_CHUA_DU_DIEU_KIEN	422	Hồ sơ chưa đủ điều kiện gửi.
QUA_NHIEU_YEU_CAU	429	Vượt tần suất gọi API cho phép.
LOI_HE_THONG	500	Lỗi hệ thống không xác định.
SERVICE_UNAVAILABLE	503	Dịch vụ phụ thuộc tạm thời gián đoạn.
OTP_QUA_SO_LAN_THU	429	Đủ 5 lần sai; trả retryAfterSeconds.
TEN_DANG_NHAP_DA_TON_TAI	409	Username đã thuộc người khác.
TEN_DANG_NHAP_KHONG_HOP_LE	400	Username không đạt định dạng.
CHUA_XAC_NHAN_CCCD	422	API-04 thiếu true hoặc OCR hiện hành chưa Pass; không gọi vendor.
HOSO_HET_HAN	409	Hồ sơ chưa gửi hết hạn 24 giờ.
KHONG_DU_DIEU_KIEN	422	API-03 hoặc API-07 xác định khách hàng dưới 18 tuổi/CCCD hết hiệu lực; dừng luồng mở mới, không tăng Fail vendor. Khác HOSO_CHUA_DU_DIEU_KIEN là chưa hoàn thành các bước bắt buộc
HOSO_KHONG_CHO_PHEP_CAP_NHAT	409	Hồ sơ không còn ở trạng thái cho phép cập nhật hoặc thao tác không đúng bước. Không thay đổi dữ liệu.

4.2 Quy tắc nghiệp vụ chính

Rule ID	Nội dung
BR-OTP	OTP gồm 6 số, hiệu lực 300 giây; chỉ mã mới nhất được dùng và chỉ dùng một lần. Tối đa 5 lần nhập sai trong một chu kỳ xác thực của hồ sơ; gửi lại không đặt lại số lần sai. Đạt giới hạn: tạm khóa xác thực 15 phút rồi cho bắt đầu chu kỳ mới. Chờ 60 giây giữa hai lần gửi; tối đa 3 lần gửi thành công trong 5 phút theo SĐT, tính cả lần đầu.
BR-EKYC	OCR và Face/Liveness dùng chung soLanThatBaiEKYC theo maHoSo, bắt đầu bằng 0. Mỗi yêu cầu được vendor xử lý và trả Fail tính 1 lần; Pass không tăng hoặc đặt lại bộ đếm. Cả Face và Liveness cùng Fail chỉ tính 1 lần. Lỗi mạng, timeout, file sai MIME/dung lượng và thao tác tự chụp lại chưa gửi không tăng bộ đếm. Đủ 3 lần: KhongHoanTatOnline, dừng online và hướng dẫn hỗ trợ/quầy; không tạo hàng đợi duyệt thủ công.
BR-CREDENTIAL	Tên đăng nhập 6–50 ký tự gồm chữ Latin không dấu, số, dấu chấm hoặc gạch dưới; duy nhất không phân biệt hoa/thường, không có khoảng trắng. Mật khẩu 8–20 ký tự, có chữ hoa, chữ thường, số và ký tự đặc biệt; không khoảng trắng, không trùng tên đăng nhập. PIN là chuỗi đúng

Rule ID	Nội dung
	6 chữ số; chặn 111111 và 123456; nhập lại phải khớp. Đăng nhập bằng tên đã thiết lập; đăng nhập bằng SĐT ngoài phạm vi.
BR-RESUME	App giữ maHoSo trên cùng thiết bị. Khi quay lại hoặc token hết hạn, xác thực lại SĐT của hồ sơ qua API-01/02 rồi dùng API-05 lấy tiến độ. Hồ sơ chưa gửi có hạn nháp 24 giờ kể từ khởi tạo; hết hạn không dùng tiếp để mở tài khoản. Hồ sơ đã gửi/đã có CIF hoặc tài khoản không bị xóa do hết hạn nháp. Chỉ khôi phục bước đã lưu; không lưu mật khẩu/PIN thô trong nháp. Không đặt lại bộ đếm do đóng App. Mất toàn bộ maHoSo hoặc tiếp tục xuyên thiết bị ngoài MVP.
BR-RETRY	Gửi lại cùng maHoSo không tạo thêm MaKH, CIF hoặc tài khoản. Nếu đã tạo tài khoản, trả kết quả hiện có. Nếu Core đã tạo CIF nhưng tài khoản chưa xong, tiếp tục đúng CIF của hồ sơ này. Khi chưa biết kết quả Core, giữ DangXuLy và tra cứu trước khi thử lại; không báo thành công hoặc tạo mới một cách mù quáng.
BR-CONFIRM	OCR Pass chưa đồng nghĩa khách hàng đã xác nhận. App ghi nhận thao tác xác nhận cho bộ ảnh hiện tại và gửi xacNhanThongTinCCCD=true tại API-04. Backend ghi nhận trước khi xử lý Face. Chụp lại CCCD làm mất hiệu lực xác nhận và kết quả Face của bộ ảnh cũ.
BR-MOCK	Các tham số OTP, ngưỡng OCR/Face 85 trên thang 0–100, token 30 phút và hạn nháp 24 giờ là cấu hình đồ án. OCR Pass cần dữ liệu bắt buộc hợp lệ; Face Pass cần điểm ≥85 và livenessPass=true. Không coi 85 là độ chính xác mô hình hoặc ngưỡng pháp lý.
BR-DONE	API-07 thành công trả DaMoTaiKhoan; API-08 xác nhận lưu và kích hoạt mới trả HoanTat. SMS lỗi không đảo trạng thái tài khoản hoặc chặn thiết lập eBanking.
API-RULE-TOKEN	Token 30 phút, đúng phạm vi maHoSo và maTaiKhoan; dùng API-01/02 để xác thực lại.
BR-EDIT	API-03, API-04 và API-06 chỉ cập nhật hồ sơ DangThucHien còn hạn, thuộc quyền token và đúng thứ tự nghiệp vụ. API-04 cần OCR hiện hành Pass và xác nhận CCCD=true; API-06 cần eKYC hiện hành đạt. Không sửa khi hồ sơ đã gửi/đã mở/hoàn tất/dừng. Hồ sơ chưa gửi hết hạn trả HOSO_HET_HAN; xung đột trạng thái trả HOSO_KHONG_CHO_PHEP_CAP_NHAT. API-08 chỉ thiết lập cho tài khoản đã mở thuộc hồ sơ; HoanTat thì trả kết quả đã có theo BR-RETRY.

V. Bảo mật tích hợp

5.1 Xác thực và phân quyền

- Mobile App sử dụng JWT Bearer Token đối với API yêu cầu đăng nhập phiên đăng ký.
- Thông tin xác thực với vendor được lưu tại secret store của môi trường triển khai; không hard-code trong mã nguồn.
- Backend kiểm tra quyền với cả maHoSo và maTaiKhoan. API-08 chỉ thao tác tài khoản được

tạo từ hồ sơ mà token onboarding được cấp quyền. Tài nguyên không tồn tại/không thuộc phiên trả 404.

5.2 Bảo mật dữ liệu

- Toàn bộ kết nối sử dụng HTTPS/TLS theo tiêu chuẩn của ngân hàng.
- Không ghi OTP, access token, mật khẩu, PIN hoặc nội dung ảnh/video eKYC vào log. Chỉ ghi metadata sự kiện đã lọc/che dữ liệu nhạy cảm
- Mật khẩu và PIN chỉ được lưu dưới dạng hash; dữ liệu nhạy cảm trên log phải được masking.

5.3 Kiểm soát lỗi và dịch vụ phụ thuộc

- Không trả stack trace hoặc thông tin hạ tầng nội bộ cho Mobile App.
- Khi vendor eKYC gián đoạn, Bank Backend trả mã SERVICE_UNAVAILABLE và không tự động tăng số lần thất bại nghiệp vụ của khách hàng.
- Giới hạn OTP theo BR-OTP. Các giới hạn hạ tầng bổ sung do môi trường triển khai xác định; không thay thế giới hạn nhập sai nghiệp vụ.

File demo: CCCD JPEG/PNG tối đa 5 MiB mỗi ảnh; khuôn mặt video MP4 tối đa 10 MiB, tối đa 10 giây. Đây là hợp đồng mock, không cam kết ảnh tĩnh đủ liveness. File sai MIME/dung lượng/thời lượng trả HTTP 400, error.code=DU_LIEU_KHONG_HOP_LE; không gọi vendor và không tăng eKYC Fail.

VI. Phụ lục

6.1 Trạng thái hồ sơ

Giá trị	Ý nghĩa
DangThucHien	Đang xác thực hoặc bổ sung hồ sơ, chưa gửi.
DangXuLy	Đã gửi; đang kiểm tra/tạo tài khoản hoặc chưa rõ kết quả Core.
DaMoTaiKhoan	Đã có CIF/STK, chưa hoàn tất eBanking/PIN.
HoanTat	Backend đã lưu thông tin đăng nhập/PIN và kích hoạt eBanking.
KhongHoanTatOnline	Hết lượt eKYC hoặc không đáp ứng điều kiện luồng mô phỏng; hướng dẫn hỗ trợ.
TuChoiMoMoi	CCCD thuộc khách hàng hiện hữu; dừng mở mới.
HetHanNhap	Hồ sơ chưa gửi quá hạn nháp 24 giờ.

6.2 Danh sách nội dung cần xác nhận trước UAT

- Base URL theo từng môi trường và cơ chế định tuyến qua API Gateway.
- Contract chính thức của EXT-01/EXT-02 và cơ chế xác thực với vendor.
- Giới hạn file, thời gian chờ và chính sách thử lại theo dịch vụ thực tế.
- Bộ mã lỗi và thông báo khi tích hợp vendor thật.
- Thiết kế CSDL và hạ tầng vận hành thực tế.